# ZTIP-IOT

## PRODUCT REQUIREMENTS DOCUMENT (PRD)

# Zero-Trust IoT Identity Provisioning Module

**Internet of Things / Critical Infrastructure Security | Rev A1 - Architecture, Atomic Requirements, Interfaces & Verification Baseline**

Mission profile. Hardware identity module for industrial IoT sensors that establishes cryptographic device identity and zero-trust network access for critical-infrastructure deployments. The market context includes operators with NERC CIP obligations, while the exact compliance allocation remains deployment controlled.

Engineering baseline. The hardware baseline uses a secure element with physical tamper-detection meshes, protected low-power operation and encapsulation intended to resist micro-probing. Embedded software supports 802.1AR-oriented device identity and secure onboarding; ECC and dynamic key rotation provide the stated cryptographic basis. Tamper or invalid trust state drives fail-closed network access.

Release boundary. Unspecified electrical limits, timing thresholds, environmental categories, certification interpretations and manufacturing acceptance values remain controlled TBC items until approved by the responsible engineering owner. Product requirements in this PRD define behavior, evidence and ownership without inventing absent numeric limits.

| Definition | Controlled product interpretation |
|---|---|
| Product class | Zero-Trust IoT Identity Provisioning Module |
| Safety / assurance | Fail-closed trust behavior on tamper, invalid firmware or trust-anchor corruption. Security functions support critical-infrastructure access control without claiming that the module alone completes site-level NERC CIP compliance. |
| Lifecycle mission | 15-year lifecycle intent with automated certificate expiry monitoring, controlled renewal, cryptographic migration/obsolescence planning and preserved device genealogy. |
| Primary architecture | Secure element + tamper mesh + protected power/clock + embedded OS + host interface + 802.1AR onboarding + ECC credential lifecycle + secure manufacturing provisioning. |
| Release philosophy | Trust claims require device-unique provenance, negative-test evidence, secure provisioning genealogy and lifecycle credential controls. Missing qualification or manufacturing evidence blocks the affected variant; it is not converted into a runtime workaround. |

# PRODUCT GOVERNANCE, TRUST MODEL & REQUIREMENT QUALITY

Industrial IoT identity must remain attributable to a controlled device instance, manufacturing record and credential state. Zero-trust access decisions depend on verifiable identity rather than network location alone. The engineering objective for governance of device identity, trust decisions and release evidence is explicit ownership: integration teams must be able to identify the trusted inputs, permitted outputs and conditions that invalidate the result.

The dominant concern is unclear ownership of identity, policy or provisioning evidence causing an untrusted device or configuration to be treated as valid. The verification package for this page therefore uses traceability review; provisioning record audit; negative trust-state testing and records the tested revision/configuration so the result can be traced when the design changes.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-GOV-001 | governance of device identity, trust decisions and release evidence shall be implemented with explicit ownership, validity rules and bounded behavior for the released configuration. | Traceability review. |
| ZTIP-GOV-002 | The design shall detect or contain unclear ownership of identity, policy or provisioning evidence causing an untrusted device or configuration to be treated as valid before it can violate the stated trust, availability or interface boundary. | Targeted governance of device identity, trust decisions and release evidence fault injection and diagnostic-state correlation. |
| ZTIP-GOV-003 | Release of this function shall require traceability review; provisioning record audit; negative trust-state testing; an unresolved result keeps the affected configuration open. | governance of device identity, trust decisions and release evidence release checklist and configuration-status audit. |

### Verification, margin and future-change rule

For governance of device identity, trust decisions and release evidence, reassess the release argument when any of these change: identity authority, trust-policy owner, provisioning workflow, certificate profile or evidence retention. Regression for governance of device identity, trust decisions and release evidence shall target only the assumptions changed and shall preserve traceability to the prior traceability review evidence rather than repeating unrelated qualification by default.

# SYSTEM BOUNDARY, ACTORS & EXPLICIT EXCLUSIONS

the boundary between the identity module, host sensor, network authenticator and provisioning services is a product-owned mechanism with installation dependencies documented separately. The module supplies cryptographic identity and network-access trust functions to an industrial IoT host. It does not become the process-control authority simply because it can authenticate a device. For the boundary between the identity module, host sensor, network authenticator and provisioning services, that separation keeps deployment choices visible without turning them into hidden assumptions inside the product claim.

Risk analysis centers on host or network assumptions expanding the module into an undocumented control or safety role. Instead of inventing a missing margin, the program keeps the unresolved parameter visible and closes it through ICD review; authority matrix; misuse-case testing; operational containment and product-release approval remain separate decisions.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-BND-001 | The product shall preserve the intended function of the boundary between the identity module, host sensor, network authenticator and provisioning services across the operational states defined for the installation. | Icd review. |
| ZTIP-BND-002 | A fault involving host or network assumptions expanding the module into an undocumented control or safety role shall produce a diagnosable state and shall not silently expand authority beyond the approved boundary. | Negative-path test for the boundary between the identity module, host sensor, network authenticator and provisioning services with recovery-state observation. |
| ZTIP-BND-003 | Qualification shall close ICD review; authority matrix; misuse-case testing with results traceable to the tested hardware, software and configuration. | Variant evidence review for the boundary between the identity module, host sensor, network authenticator and provisioning services and production-approval gate. |

### Verification, margin and future-change rule

For the boundary between the identity module, host sensor, network authenticator and provisioning services, reassess the release argument when any of these change: host interface, network authenticator, onboarding server, service workflow or deployment topology. Regression for the boundary between the identity module, host sensor, network authenticator and provisioning services shall target only the assumptions changed and shall preserve traceability to the prior ICD review evidence rather than repeating unrelated qualification by default.

# DEVICE IDENTITY ROOT & UNIQUE DEVICE BINDING

The released architecture assigns the hardware-rooted device identity its own assurance boundary. A secure element anchors the device identity so that certificates and onboarding assertions are bound to a controlled hardware instance. Identity export must not create an equivalent cloneable trust anchor. Interfaces crossing the the hardware-rooted device identity boundary carry status or validity information so a convenience service cannot silently acquire trusted authority.

Failure analysis addresses identity cloning, duplicate provisioning or weak binding between certificate material and the physical device. Diagnostic outputs must distinguish bad input, internal malfunction and incomplete engineering evidence, while secure-element key-origin evidence; uniqueness audit; clone-attempt negative test provides the objective basis for closing the mechanism.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-IDR-001 | the hardware-rooted device identity shall have a controlled interface contract covering initialization, normal service, fault handling and authorized maintenance. | Secure-element key-origin evidence. |
| ZTIP-IDR-002 | The implementation shall prevent identity cloning, duplicate provisioning or weak binding between certificate material and the physical device from being accepted as valid trusted behavior or bypassing local protection logic. | Boundary-condition campaign for the hardware-rooted device identity with event-log review. |
| ZTIP-IDR-003 | Production equivalence for this function depends on secure-element key-origin evidence; uniqueness audit; clone-attempt negative test; a changed dependency reopens the affected regression. | the hardware-rooted device identity traceability audit with regression-closure review. |

### Verification, margin and future-change rule

For the hardware-rooted device identity, reassess the release argument when any of these change: secure element, identity derivation, manufacturing serial scheme, certificate subject profile or replacement policy. Regression for the hardware-rooted device identity shall target only the assumptions changed and shall preserve traceability to the prior secure-element key-origin evidence evidence rather than repeating unrelated qualification by default.

# SECURE ELEMENT ARCHITECTURE & PROTECTED OBJECTS

Across startup, normal service, degraded operation and authorized recovery, secure-element storage, cryptographic operations and access control must preserve the behavior described here. Protected objects include the device identity root, private keys, trust anchors and security counters needed by onboarding and renewal. Host software receives only the outputs required by the protocol. State transitions for secure-element storage, cryptographic operations and access control are verified from observable conditions rather than inferred from nominal success alone.

A credible assurance case must show that unauthorized host access, unintended key export or misuse of privileged secure-element commands. Verification uses SE configuration review; command-permission test; key-export negative test across nominal, boundary and injected-fault conditions, with dependency versions retained so later regression can be scoped technically.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-SE-001 | The architecture shall provide observability for secure-element storage, cryptographic operations and access control sufficient to distinguish valid operation from degraded or compromised conditions. | Se configuration review. |
| ZTIP-SE-002 | When unauthorized host access, unintended key export or misuse of privileged secure-element commands occurs, containment shall follow the defined policy and retain the evidence needed for diagnosis. | Injected-failure test for secure-element storage, cryptographic operations and access control with containment and restart evidence. |
| ZTIP-SE-003 | Acceptance shall be based on SE configuration review; command-permission test; key-export negative test, including configuration traceability where it affects the conclusion. | secure-element storage, cryptographic operations and access control configuration baseline and qualification-status review. |

### Verification, margin and future-change rule

For secure-element storage, cryptographic operations and access control, reassess the release argument when any of these change: SE family, firmware, access policy, object layout, cryptographic library or host-command mapping. Regression for secure-element storage, cryptographic operations and access control shall target only the assumptions changed and shall preserve traceability to the prior SE configuration review evidence rather than repeating unrelated qualification by default.

# PHYSICAL TAMPER MESH & DETECTION CHAIN

Engineering ownership of tamper-mesh sensing and physical-attack detection includes its dependencies and failure evidence. Physical tamper meshes provide an independent signal that the encapsulated identity boundary may have been opened, drilled, cut or otherwise attacked. The detection path must remain meaningful through manufacturing and field aging. The release record therefore ties tamper-mesh sensing and physical-attack detection to the exact implementation and configured external services used in verification.

The release risk is tamper bypass, latent mesh failure or false acceptance after physical intrusion. Evidence from continuity test; destructive tamper campaign; aging correlation is reviewed together with interface state and recovery behavior; an engineering gap blocks the affected variant rather than being disguised as a runtime derating strategy.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-TAM-001 | tamper-mesh sensing and physical-attack detection shall be dimensioned and configured for the declared mission profile without relying on undocumented external behavior. | Continuity test. |
| ZTIP-TAM-002 | The consequence of tamper bypass, latent mesh failure or false acceptance after physical intrusion shall be bounded so that recovery, fail-closed behavior or service action remains deterministic. | Misuse-case test for tamper-mesh sensing and physical-attack detection plus diagnostic and recovery verification. |
| ZTIP-TAM-003 | Engineering release shall close continuity test; destructive tamper campaign; aging correlation; supplier, layout, firmware or installation changes that alter the argument require focused retest. | Production-equivalence decision record for tamper-mesh sensing and physical-attack detection. |

### Verification, margin and future-change rule

For tamper-mesh sensing and physical-attack detection, reassess the release argument when any of these change: mesh geometry, substrate, routing, threshold circuit, encapsulation process or enclosure stack. Regression for tamper-mesh sensing and physical-attack detection shall target only the assumptions changed and shall preserve traceability to the prior continuity test evidence rather than repeating unrelated qualification by default.

# PROTECTED POWER, CLOCK & RESET BEHAVIOR

The product treats protected power, clock and reset behavior of the trust boundary as a controlled capability rather than a generic platform feature. The secure element and tamper logic require deterministic behavior through brownout, clock disturbance and reset. Security state must not become permissive merely because the host experiences an unstable supply. Any dependency of protected power, clock and reset behavior of the trust boundary is named in the interface or configuration baseline so its loss can be distinguished from an internal defect.

The design review asks whether glitch-induced state corruption, rollback or fail-open access during power or clock disturbance. That question is answered with brownout/glitch test; reset-sequence review; state-retention verification, supplemented by negative-path observation where necessary to prove that the mechanism fails in the intended direction.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-PCLK-001 | The released implementation of protected power, clock and reset behavior of the trust boundary shall expose the status required by diagnostics and lifecycle management without disclosing protected secrets or unsafe controls. | Brownout/glitch test. |
| ZTIP-PCLK-002 | The product shall treat glitch-induced state corruption, rollback or fail-open access during power or clock disturbance as an invalid or degraded condition rather than accepting it as nominal input. | Fault stimulation of protected power, clock and reset behavior of the trust boundary with interface-state and audit-record review. |
| ZTIP-PCLK-003 | Objective evidence for this requirement shall include brownout/glitch test; reset-sequence review; state-retention verification, using pass/fail criteria owned by the product verification plan. | DVP closure for protected power, clock and reset behavior of the trust boundary and controlled release-board review. |

### Verification, margin and future-change rule

For protected power, clock and reset behavior of the trust boundary, reassess the release argument when any of these change: regulator, decoupling, clock source, reset topology, hold-up, sleep entry or wake sequence. Regression for protected power, clock and reset behavior of the trust boundary shall target only the assumptions changed and shall preserve traceability to the prior brownout/glitch test evidence rather than repeating unrelated qualification by default.

# HOST INTERFACE, COMMAND AUTHORITY & RATE CONTROL

The host sensor invokes identity, attestation and onboarding services through a bounded command interface. Privileged operations require state and authorization checks that are independent of ordinary application requests. The engineering objective for the electrical and logical host interface is explicit ownership: integration teams must be able to identify the trusted inputs, permitted outputs and conditions that invalidate the result.

The dominant concern is host compromise invoking privileged security functions or exhausting the secure element through command abuse. The verification package for this page therefore uses protocol negative test; rate-limit test; privilege matrix review and records the tested revision/configuration so the result can be traced when the design changes.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-HOST-001 | the electrical and logical host interface shall be implemented with explicit ownership, validity rules and bounded behavior for the released configuration. | Protocol negative test. |
| ZTIP-HOST-002 | The design shall detect or contain host compromise invoking privileged security functions or exhausting the secure element through command abuse before it can violate the stated trust, availability or interface boundary. | Abnormal-condition test for the electrical and logical host interface and degraded-state trace review. |
| ZTIP-HOST-003 | Release of this function shall require protocol negative test; rate-limit test; privilege matrix review; an unresolved result keeps the affected configuration open. | the electrical and logical host interface release checklist and configuration-status audit. |

### Verification, margin and future-change rule

For the electrical and logical host interface, reassess the release argument when any of these change: host bus, driver, command set, privilege mapping, queue depth or timeout policy. Regression for the electrical and logical host interface shall target only the assumptions changed and shall preserve traceability to the prior protocol negative test evidence rather than repeating unrelated qualification by default.

# SECURE BOOT, MEASURED STATE & FIRMWARE TRUST

firmware authenticity and boot-state trust is a product-owned mechanism with installation dependencies documented separately. Only approved firmware may initialize the identity services. Invalid or corrupted firmware must not gain access to credentials or assert a trusted device posture. For firmware authenticity and boot-state trust, that separation keeps deployment choices visible without turning them into hidden assumptions inside the product claim.

Risk analysis centers on modified firmware reaching credential operations or presenting stale trusted state. Instead of inventing a missing margin, the program keeps the unresolved parameter visible and closes it through signature-failure test; boot-chain review; recovery-state verification; operational containment and product-release approval remain separate decisions.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-BOOT-001 | The product shall preserve the intended function of firmware authenticity and boot-state trust across the operational states defined for the installation. | Signature-failure test. |
| ZTIP-BOOT-002 | A fault involving modified firmware reaching credential operations or presenting stale trusted state shall produce a diagnosable state and shall not silently expand authority beyond the approved boundary. | Stress/fault test for firmware authenticity and boot-state trust with recovery and non-bypass evidence. |
| ZTIP-BOOT-003 | Qualification shall close signature-failure test; boot-chain review; recovery-state verification with results traceable to the tested hardware, software and configuration. | Variant evidence review for firmware authenticity and boot-state trust and production-approval gate. |

### Verification, margin and future-change rule

For firmware authenticity and boot-state trust, reassess the release argument when any of these change: boot ROM, signing key, image format, anti-rollback policy, bootloader or recovery partition. Regression for firmware authenticity and boot-state trust shall target only the assumptions changed and shall preserve traceability to the prior signature-failure test evidence rather than repeating unrelated qualification by default.

# EMBEDDED OS, PRIVILEGE SEPARATION & WATCHDOGS

The released architecture assigns embedded os privilege separation and supervision its own assurance boundary. The embedded OS handles onboarding, certificate state and host communication while preserving isolation around credential-management code. Watchdog recovery must not erase the evidence needed to understand repeated failures. Interfaces crossing the embedded os privilege separation and supervision boundary carry status or validity information so a convenience service cannot silently acquire trusted authority.

Failure analysis addresses task corruption, deadlock or privilege escalation changing trust decisions. Diagnostic outputs must distinguish bad input, internal malfunction and incomplete engineering evidence, while fault injection; scheduler/watchdog test; privilege review provides the objective basis for closing the mechanism.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-OS-001 | embedded OS privilege separation and supervision shall have a controlled interface contract covering initialization, normal service, fault handling and authorized maintenance. | Fault injection. |
| ZTIP-OS-002 | The implementation shall prevent task corruption, deadlock or privilege escalation changing trust decisions from being accepted as valid trusted behavior or bypassing local protection logic. | Targeted embedded os privilege separation and supervision fault injection and diagnostic-state correlation. |
| ZTIP-OS-003 | Production equivalence for this function depends on fault injection; scheduler/watchdog test; privilege review; a changed dependency reopens the affected regression. | embedded OS privilege separation and supervision traceability audit with regression-closure review. |

### Verification, margin and future-change rule

For embedded os privilege separation and supervision, reassess the release argument when any of these change: OS version, task partition, IPC, watchdog interval, memory protection or exception handling. Regression for embedded os privilege separation and supervision shall target only the assumptions changed and shall preserve traceability to the prior fault injection evidence rather than repeating unrelated qualification by default.

# IEEE 802.1AR IDENTITY REPRESENTATION

Across startup, normal service, degraded operation and authorized recovery, 802.1ar device identity handling must preserve the behavior described here. The product supports 802.1AR-based identity semantics for secure onboarding while retaining exact certificate profiles and deployment mappings as controlled program parameters. State transitions for 802.1ar device identity handling are verified from observable conditions rather than inferred from nominal success alone.

A credible assurance case must show that incorrect certificate identity mapping or use of an expired, revoked or mismatched device identity. Verification uses certificate-profile test; chain validation; interoperability review across nominal, boundary and injected-fault conditions, with dependency versions retained so later regression can be scoped technically.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-IAR-001 | The architecture shall provide observability for 802.1AR device identity handling sufficient to distinguish valid operation from degraded or compromised conditions. | Certificate-profile test. |
| ZTIP-IAR-002 | When incorrect certificate identity mapping or use of an expired, revoked or mismatched device identity occurs, containment shall follow the defined policy and retain the evidence needed for diagnosis. | Negative-path test for 802.1ar device identity handling with recovery-state observation. |
| ZTIP-IAR-003 | Acceptance shall be based on certificate-profile test; chain validation; interoperability review, including configuration traceability where it affects the conclusion. | 802.1AR device identity handling configuration baseline and qualification-status review. |

### Verification, margin and future-change rule

For 802.1ar device identity handling, reassess the release argument when any of these change: certificate fields, issuer hierarchy, device identifier mapping, renewal model or interoperability profile. Regression for 802.1ar device identity handling shall target only the assumptions changed and shall preserve traceability to the prior certificate-profile test evidence rather than repeating unrelated qualification by default.

# SECURE DEVICE ONBOARDING STATE MACHINE

Engineering ownership of secure onboarding and network-admission sequencing includes its dependencies and failure evidence. Onboarding transitions from manufactured identity to authenticated operational access without exposing private key material. Each state has explicit entry conditions, rollback behavior and audit evidence. The release record therefore ties secure onboarding and network-admission sequencing to the exact implementation and configured external services used in verification.

The release risk is partial onboarding leaving ambiguous identity state or granting access before trust checks complete. Evidence from state-machine test; interrupted-onboarding recovery; audit-log review is reviewed together with interface state and recovery behavior; an engineering gap blocks the affected variant rather than being disguised as a runtime derating strategy.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-ONB-001 | secure onboarding and network-admission sequencing shall be dimensioned and configured for the declared mission profile without relying on undocumented external behavior. | State-machine test. |
| ZTIP-ONB-002 | The consequence of partial onboarding leaving ambiguous identity state or granting access before trust checks complete shall be bounded so that recovery, fail-closed behavior or service action remains deterministic. | Boundary-condition campaign for secure onboarding and network-admission sequencing with event-log review. |
| ZTIP-ONB-003 | Engineering release shall close state-machine test; interrupted-onboarding recovery; audit-log review; supplier, layout, firmware or installation changes that alter the argument require focused retest. | Production-equivalence decision record for secure onboarding and network-admission sequencing. |

### Verification, margin and future-change rule

For secure onboarding and network-admission sequencing, reassess the release argument when any of these change: onboarding protocol, registrar, bootstrap credential, network policy, retry behavior or service tool. Regression for secure onboarding and network-admission sequencing shall target only the assumptions changed and shall preserve traceability to the prior state-machine test evidence rather than repeating unrelated qualification by default.

# ECC CRYPTOGRAPHIC SERVICES & ALGORITHM AGILITY

The product treats ecc cryptographic operations and controlled algorithm selection as a controlled capability rather than a generic platform feature. Elliptic Curve Cryptography provides the asymmetric trust mechanism specified for the module. Curve choice, key length and protocol profile remain controlled configuration rather than being invented here. Any dependency of ecc cryptographic operations and controlled algorithm selection is named in the interface or configuration baseline so its loss can be distinguished from an internal defect.

The design review asks whether algorithm misuse, weak parameter selection or implementation errors exposing long-lived identity keys. That question is answered with known-answer tests; crypto-library review; interoperability testing, supplemented by negative-path observation where necessary to prove that the mechanism fails in the intended direction.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-ECC-001 | The released implementation of ECC cryptographic operations and controlled algorithm selection shall expose the status required by diagnostics and lifecycle management without disclosing protected secrets or unsafe controls. | Known-answer tests. |
| ZTIP-ECC-002 | The product shall treat algorithm misuse, weak parameter selection or implementation errors exposing long-lived identity keys as an invalid or degraded condition rather than accepting it as nominal input. | Injected-failure test for ecc cryptographic operations and controlled algorithm selection with containment and restart evidence. |
| ZTIP-ECC-003 | Objective evidence for this requirement shall include known-answer tests; crypto-library review; interoperability testing, using pass/fail criteria owned by the product verification plan. | DVP closure for ecc cryptographic operations and controlled algorithm selection and controlled release-board review. |

### Verification, margin and future-change rule

For ecc cryptographic operations and controlled algorithm selection, reassess the release argument when any of these change: ECC implementation, curve/profile approval, accelerator, random source, protocol binding or cryptographic library. Regression for ecc cryptographic operations and controlled algorithm selection shall target only the assumptions changed and shall preserve traceability to the prior known-answer tests evidence rather than repeating unrelated qualification by default.

# ENTROPY, KEY GENERATION & SECRET MATERIAL ORIGIN

Private keys require a defensible origin and shall not be reconstructed from predictable manufacturing data. Random-number health status must be handled as a security state, not merely a diagnostic detail. The engineering objective for entropy and private-key generation is explicit ownership: integration teams must be able to identify the trusted inputs, permitted outputs and conditions that invalidate the result.

The dominant concern is insufficient entropy or repeated private keys across devices. The verification package for this page therefore uses entropy assessment; duplicate-key search; RNG health fault injection and records the tested revision/configuration so the result can be traced when the design changes.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-RNG-001 | entropy and private-key generation shall be implemented with explicit ownership, validity rules and bounded behavior for the released configuration. | Entropy assessment. |
| ZTIP-RNG-002 | The design shall detect or contain insufficient entropy or repeated private keys across devices before it can violate the stated trust, availability or interface boundary. | Misuse-case test for entropy and private-key generation plus diagnostic and recovery verification. |
| ZTIP-RNG-003 | Release of this function shall require entropy assessment; duplicate-key search; RNG health fault injection; an unresolved result keeps the affected configuration open. | entropy and private-key generation release checklist and configuration-status audit. |

### Verification, margin and future-change rule

For entropy and private-key generation, reassess the release argument when any of these change: entropy source, DRBG, manufacturing environment, personalization flow or key-generation firmware. Regression for entropy and private-key generation shall target only the assumptions changed and shall preserve traceability to the prior entropy assessment evidence rather than repeating unrelated qualification by default.

# DYNAMIC KEY ROTATION & ACTIVE-SESSION CONTINUITY

dynamic key rotation is a product-owned mechanism with installation dependencies documented separately. Dynamic key rotation limits dependence on a single long-lived operational credential while preserving controlled service continuity. Rotation must not create overlapping authorities that remain valid indefinitely. For dynamic key rotation, that separation keeps deployment choices visible without turning them into hidden assumptions inside the product claim.

Risk analysis centers on stale keys remaining active, failed rollover locking out valid devices, or split trust state. Instead of inventing a missing margin, the program keeps the unresolved parameter visible and closes it through rotation-window test; stale-key rejection; interruption/recovery test; operational containment and product-release approval remain separate decisions.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-ROT-001 | The product shall preserve the intended function of dynamic key rotation across the operational states defined for the installation. | Rotation-window test. |
| ZTIP-ROT-002 | A fault involving stale keys remaining active, failed rollover locking out valid devices, or split trust state shall produce a diagnosable state and shall not silently expand authority beyond the approved boundary. | Fault stimulation of dynamic key rotation with interface-state and audit-record review. |
| ZTIP-ROT-003 | Qualification shall close rotation-window test; stale-key rejection; interruption/recovery test with results traceable to the tested hardware, software and configuration. | Variant evidence review for dynamic key rotation and production-approval gate. |

### Verification, margin and future-change rule

For dynamic key rotation, reassess the release argument when any of these change: rotation cadence, overlap policy, issuer, time source, network availability or rollback procedure. Regression for dynamic key rotation shall target only the assumptions changed and shall preserve traceability to the prior rotation-window test evidence rather than repeating unrelated qualification by default.

# CERTIFICATE LIFECYCLE, EXPIRY & RENEWAL

The released architecture assigns certificate expiry monitoring and renewal state its own assurance boundary. Certificate expiry monitoring runs independently of application convenience so that a device cannot remain silently trusted after its credential validity has ended. Renewal status is visible to diagnostics before loss of service. Interfaces crossing the certificate expiry monitoring and renewal state boundary carry status or validity information so a convenience service cannot silently acquire trusted authority.

Failure analysis addresses expired credentials remaining accepted or renewal failure occurring without actionable warning. Diagnostic outputs must distinguish bad input, internal malfunction and incomplete engineering evidence, while expiry simulation; renewal test; diagnostic lead-time review provides the objective basis for closing the mechanism.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-CRT-001 | certificate expiry monitoring and renewal state shall have a controlled interface contract covering initialization, normal service, fault handling and authorized maintenance. | Expiry simulation. |
| ZTIP-CRT-002 | The implementation shall prevent expired credentials remaining accepted or renewal failure occurring without actionable warning from being accepted as valid trusted behavior or bypassing local protection logic. | Abnormal-condition test for certificate expiry monitoring and renewal state and degraded-state trace review. |
| ZTIP-CRT-003 | Production equivalence for this function depends on expiry simulation; renewal test; diagnostic lead-time review; a changed dependency reopens the affected regression. | certificate expiry monitoring and renewal state traceability audit with regression-closure review. |

### Verification, margin and future-change rule

For certificate expiry monitoring and renewal state, reassess the release argument when any of these change: certificate lifetime, time service, renewal transport, issuer hierarchy or maintenance policy. Regression for certificate expiry monitoring and renewal state shall target only the assumptions changed and shall preserve traceability to the prior expiry simulation evidence rather than repeating unrelated qualification by default.

# TRUST ANCHOR INTEGRITY & CORRUPTION RESPONSE

Across startup, normal service, degraded operation and authorized recovery, trust-anchor integrity and recovery must preserve the behavior described here. Trust anchors are protected security objects. Corruption, unauthorized replacement or inconsistent anchor sets must produce a non-trusted condition until a controlled recovery path re-establishes provenance. State transitions for trust-anchor integrity and recovery are verified from observable conditions rather than inferred from nominal success alone.

A credible assurance case must show that corrupt or substituted trust anchors authorizing an attacker-controlled chain. Verification uses anchor-corruption fault test; replacement authorization test; recovery audit across nominal, boundary and injected-fault conditions, with dependency versions retained so later regression can be scoped technically.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-TA-001 | The architecture shall provide observability for trust-anchor integrity and recovery sufficient to distinguish valid operation from degraded or compromised conditions. | Anchor-corruption fault test. |
| ZTIP-TA-002 | When corrupt or substituted trust anchors authorizing an attacker-controlled chain occurs, containment shall follow the defined policy and retain the evidence needed for diagnosis. | Stress/fault test for trust-anchor integrity and recovery with recovery and non-bypass evidence. |
| ZTIP-TA-003 | Acceptance shall be based on anchor-corruption fault test; replacement authorization test; recovery audit, including configuration traceability where it affects the conclusion. | trust-anchor integrity and recovery configuration baseline and qualification-status review. |

### Verification, margin and future-change rule

For trust-anchor integrity and recovery, reassess the release argument when any of these change: anchor store, update package, recovery credential, secure element object policy or factory recovery process. Regression for trust-anchor integrity and recovery shall target only the assumptions changed and shall preserve traceability to the prior anchor-corruption fault test evidence rather than repeating unrelated qualification by default.

# FAIL-CLOSED ACCESS REVOCATION ON TAMPER

Engineering ownership of fail-closed network-access revocation after tamper includes its dependencies and failure evidence. The stated safety/security position is to fail closed when tamper is detected. Access revocation must not depend solely on a remote cloud response because connectivity may be unavailable at the same time. The release record therefore ties fail-closed network-access revocation after tamper to the exact implementation and configured external services used in verification.

The release risk is tamper detection leaving network credentials usable or allowing cached admission to persist. Evidence from tamper-to-revocation test; offline-network test; host-access negative test is reviewed together with interface state and recovery behavior; an engineering gap blocks the affected variant rather than being disguised as a runtime derating strategy.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-FC-001 | fail-closed network-access revocation after tamper shall be dimensioned and configured for the declared mission profile without relying on undocumented external behavior. | Tamper-to-revocation test. |
| ZTIP-FC-002 | The consequence of tamper detection leaving network credentials usable or allowing cached admission to persist shall be bounded so that recovery, fail-closed behavior or service action remains deterministic. | Targeted fail-closed network-access revocation after tamper fault injection and diagnostic-state correlation. |
| ZTIP-FC-003 | Engineering release shall close tamper-to-revocation test; offline-network test; host-access negative test; supplier, layout, firmware or installation changes that alter the argument require focused retest. | Production-equivalence decision record for fail-closed network-access revocation after tamper. |

### Verification, margin and future-change rule

For fail-closed network-access revocation after tamper, reassess the release argument when any of these change: tamper policy, credential invalidation method, network cache behavior, recovery authorization or service workflow. Regression for fail-closed network-access revocation after tamper shall target only the assumptions changed and shall preserve traceability to the prior tamper-to-revocation test evidence rather than repeating unrelated qualification by default.

# INVALID FIRMWARE & UNTRUSTED-STATE CONTAINMENT

The product treats containment of invalid firmware or untrusted boot state as a controlled capability rather than a generic platform feature. Firmware authenticity failure is treated as loss of trust. The module may expose minimal service diagnostics, but operational identity services remain unavailable until authorized recovery completes. Any dependency of containment of invalid firmware or untrusted boot state is named in the interface or configuration baseline so its loss can be distinguished from an internal defect.

The design review asks whether recovery code or diagnostic mode becoming a bypass around credential protection. That question is answered with corrupt-image test; recovery-mode penetration test; service-interface review, supplemented by negative-path observation where necessary to prove that the mechanism fails in the intended direction.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-IFW-001 | The released implementation of containment of invalid firmware or untrusted boot state shall expose the status required by diagnostics and lifecycle management without disclosing protected secrets or unsafe controls. | Corrupt-image test. |
| ZTIP-IFW-002 | The product shall treat recovery code or diagnostic mode becoming a bypass around credential protection as an invalid or degraded condition rather than accepting it as nominal input. | Negative-path test for containment of invalid firmware or untrusted boot state with recovery-state observation. |
| ZTIP-IFW-003 | Objective evidence for this requirement shall include corrupt-image test; recovery-mode penetration test; service-interface review, using pass/fail criteria owned by the product verification plan. | DVP closure for containment of invalid firmware or untrusted boot state and controlled release-board review. |

### Verification, margin and future-change rule

For containment of invalid firmware or untrusted boot state, reassess the release argument when any of these change: recovery image, diagnostic channel, factory credential, boot policy or maintenance tooling. Regression for containment of invalid firmware or untrusted boot state shall target only the assumptions changed and shall preserve traceability to the prior corrupt-image test evidence rather than repeating unrelated qualification by default.

# HOST COMPROMISE CONTAINMENT & SECRET NON-EXPORT

Zero-trust behavior assumes the host application may be less trusted than the identity module. Host compromise must not allow private-key extraction or permanent redefinition of the module trust anchors. The engineering objective for containment of a compromised host is explicit ownership: integration teams must be able to identify the trusted inputs, permitted outputs and conditions that invalidate the result.

The dominant concern is malicious host code extracting secrets, altering roots or suppressing tamper state. The verification package for this page therefore uses host-fuzzing; privilege-negative test; key-export audit and records the tested revision/configuration so the result can be traced when the design changes.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-HC-001 | containment of a compromised host shall be implemented with explicit ownership, validity rules and bounded behavior for the released configuration. | Host-fuzzing. |
| ZTIP-HC-002 | The design shall detect or contain malicious host code extracting secrets, altering roots or suppressing tamper state before it can violate the stated trust, availability or interface boundary. | Boundary-condition campaign for containment of a compromised host with event-log review. |
| ZTIP-HC-003 | Release of this function shall require host-fuzzing; privilege-negative test; key-export audit; an unresolved result keeps the affected configuration open. | containment of a compromised host release checklist and configuration-status audit. |

### Verification, margin and future-change rule

For containment of a compromised host, reassess the release argument when any of these change: host driver, API surface, DMA/physical bus access, debug policy or service permissions. Regression for containment of a compromised host shall target only the assumptions changed and shall preserve traceability to the prior host-fuzzing evidence rather than repeating unrelated qualification by default.

# NETWORK ACCESS POLICY INPUTS & DECISION OUTPUTS

network-access policy inputs and trust-decision outputs is a product-owned mechanism with installation dependencies documented separately. The module supplies cryptographic evidence and state needed by the deployment access policy but does not silently own enterprise authorization rules. Policy version and decision inputs remain attributable. For network-access policy inputs and trust-decision outputs, that separation keeps deployment choices visible without turning them into hidden assumptions inside the product claim.

Risk analysis centers on policy ambiguity or stale posture data producing unauthorized network admission. Instead of inventing a missing margin, the program keeps the unresolved parameter visible and closes it through policy-interface review; stale-state test; decision-trace audit; operational containment and product-release approval remain separate decisions.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-NAP-001 | The product shall preserve the intended function of network-access policy inputs and trust-decision outputs across the operational states defined for the installation. | Policy-interface review. |
| ZTIP-NAP-002 | A fault involving policy ambiguity or stale posture data producing unauthorized network admission shall produce a diagnosable state and shall not silently expand authority beyond the approved boundary. | Injected-failure test for network-access policy inputs and trust-decision outputs with containment and restart evidence. |
| ZTIP-NAP-003 | Qualification shall close policy-interface review; stale-state test; decision-trace audit with results traceable to the tested hardware, software and configuration. | Variant evidence review for network-access policy inputs and trust-decision outputs and production-approval gate. |

### Verification, margin and future-change rule

For network-access policy inputs and trust-decision outputs, reassess the release argument when any of these change: policy schema, authenticator interface, posture claims, cache duration or enterprise access model. Regression for network-access policy inputs and trust-decision outputs shall target only the assumptions changed and shall preserve traceability to the prior policy-interface review evidence rather than repeating unrelated qualification by default.

# REVOCATION, DENYLIST & OFFLINE CONNECTIVITY BEHAVIOR

The released architecture assigns credential revocation and offline behavior its own assurance boundary. Revoked or denied identities must not regain access merely because the module or network is temporarily offline. Offline operation requires a controlled policy describing cached trust, time validity and recovery. Interfaces crossing the credential revocation and offline behavior boundary carry status or validity information so a convenience service cannot silently acquire trusted authority.

Failure analysis addresses loss of backend connectivity extending trust beyond approved revocation or expiry rules. Diagnostic outputs must distinguish bad input, internal malfunction and incomplete engineering evidence, while offline revocation simulation; cache-age test; reconnect reconciliation provides the objective basis for closing the mechanism.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-REV-001 | credential revocation and offline behavior shall have a controlled interface contract covering initialization, normal service, fault handling and authorized maintenance. | Offline revocation simulation. |
| ZTIP-REV-002 | The implementation shall prevent loss of backend connectivity extending trust beyond approved revocation or expiry rules from being accepted as valid trusted behavior or bypassing local protection logic. | Misuse-case test for credential revocation and offline behavior plus diagnostic and recovery verification. |
| ZTIP-REV-003 | Production equivalence for this function depends on offline revocation simulation; cache-age test; reconnect reconciliation; a changed dependency reopens the affected regression. | credential revocation and offline behavior traceability audit with regression-closure review. |

### Verification, margin and future-change rule

For credential revocation and offline behavior, reassess the release argument when any of these change: revocation source, cache policy, time base, network outage assumption or synchronisation method. Regression for credential revocation and offline behavior shall target only the assumptions changed and shall preserve traceability to the prior offline revocation simulation evidence rather than repeating unrelated qualification by default.

# SECURE TIME, MONOTONIC STATE & EXPIRY DECISIONS

Across startup, normal service, degraded operation and authorized recovery, time and monotonic-state support for credential decisions must preserve the behavior described here. Certificate expiry, rotation and anti-rollback decisions depend on trustworthy progression of time or monotonic state. The architecture shall detect invalid time rather than accepting a backward jump as ordinary operation. State transitions for time and monotonic-state support for credential decisions are verified from observable conditions rather than inferred from nominal success alone.

A credible assurance case must show that clock rollback, reset or battery loss making expired or rolled-back state appear valid. Verification uses time-jump test; monotonic-counter test; power-cycle correlation across nominal, boundary and injected-fault conditions, with dependency versions retained so later regression can be scoped technically.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-TIM-001 | The architecture shall provide observability for time and monotonic-state support for credential decisions sufficient to distinguish valid operation from degraded or compromised conditions. | Time-jump test. |
| ZTIP-TIM-002 | When clock rollback, reset or battery loss making expired or rolled-back state appear valid occurs, containment shall follow the defined policy and retain the evidence needed for diagnosis. | Fault stimulation of time and monotonic-state support for credential decisions with interface-state and audit-record review. |
| ZTIP-TIM-003 | Acceptance shall be based on time-jump test; monotonic-counter test; power-cycle correlation, including configuration traceability where it affects the conclusion. | time and monotonic-state support for credential decisions configuration baseline and qualification-status review. |

### Verification, margin and future-change rule

For time and monotonic-state support for credential decisions, reassess the release argument when any of these change: RTC source, monotonic counter, host time input, synchronization method or backup power. Regression for time and monotonic-state support for credential decisions shall target only the assumptions changed and shall preserve traceability to the prior time-jump test evidence rather than repeating unrelated qualification by default.

# ULTRA-LOW-POWER SLEEP STATES & TRUST RETENTION

Engineering ownership of ultra-low-power sleep behavior includes its dependencies and failure evidence. Battery-operated sensor integration requires sleep states that reduce quiescent load while preserving identity, tamper and anti-rollback semantics. Wake behavior must not require insecure reinitialization shortcuts. The release record therefore ties ultra-low-power sleep behavior to the exact implementation and configured external services used in verification.

The release risk is sleep erasing security state, masking tamper, or drawing unbudgeted current. Evidence from sleep-current measurement; wake-state test; tamper-during-sleep test is reviewed together with interface state and recovery behavior; an engineering gap blocks the affected variant rather than being disguised as a runtime derating strategy.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-ULP-001 | ultra-low-power sleep behavior shall be dimensioned and configured for the declared mission profile without relying on undocumented external behavior. | Sleep-current measurement. |
| ZTIP-ULP-002 | The consequence of sleep erasing security state, masking tamper, or drawing unbudgeted current shall be bounded so that recovery, fail-closed behavior or service action remains deterministic. | Abnormal-condition test for ultra-low-power sleep behavior and degraded-state trace review. |
| ZTIP-ULP-003 | Engineering release shall close sleep-current measurement; wake-state test; tamper-during-sleep test; supplier, layout, firmware or installation changes that alter the argument require focused retest. | Production-equivalence decision record for ultra-low-power sleep behavior. |

### Verification, margin and future-change rule

For ultra-low-power sleep behavior, reassess the release argument when any of these change: sleep mode, retention domain, wake source, polling cadence or sensor-host power architecture. Regression for ultra-low-power sleep behavior shall target only the assumptions changed and shall preserve traceability to the prior sleep-current measurement evidence rather than repeating unrelated qualification by default.

# WAKE, RESUME & RE-AUTHENTICATION SEQUENCING

The product treats wake/resume and re-authentication sequencing as a controlled capability rather than a generic platform feature. Resume from deep sleep re-establishes host communication and network trust in a controlled order. Cached sessions are accepted only when their validity remains demonstrable after the sleep interval. Any dependency of wake/resume and re-authentication sequencing is named in the interface or configuration baseline so its loss can be distinguished from an internal defect.

The design review asks whether stale session reuse or host commands arriving before credential and tamper state are restored. That question is answered with resume sequencing test; stale-session rejection; race-condition test, supplemented by negative-path observation where necessary to prove that the mechanism fails in the intended direction.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-WAK-001 | The released implementation of wake/resume and re-authentication sequencing shall expose the status required by diagnostics and lifecycle management without disclosing protected secrets or unsafe controls. | Resume sequencing test. |
| ZTIP-WAK-002 | The product shall treat stale session reuse or host commands arriving before credential and tamper state are restored as an invalid or degraded condition rather than accepting it as nominal input. | Stress/fault test for wake/resume and re-authentication sequencing with recovery and non-bypass evidence. |
| ZTIP-WAK-003 | Objective evidence for this requirement shall include resume sequencing test; stale-session rejection; race-condition test, using pass/fail criteria owned by the product verification plan. | DVP closure for wake/resume and re-authentication sequencing and controlled release-board review. |

### Verification, margin and future-change rule

For wake/resume and re-authentication sequencing, reassess the release argument when any of these change: wake source, session cache, host boot timing, network reconnect or credential refresh policy. Regression for wake/resume and re-authentication sequencing shall target only the assumptions changed and shall preserve traceability to the prior resume sequencing test evidence rather than repeating unrelated qualification by default.

# BROWNOUT, TRANSIENT & POWER-LOSS SECURITY BEHAVIOR

Power loss during key update, certificate renewal or secure-state commit must not create ambiguous authorization state. Transactional state handling is required for security-critical nonvolatile updates. The engineering objective for power integrity around credential operations is explicit ownership: integration teams must be able to identify the trusted inputs, permitted outputs and conditions that invalidate the result.

The dominant concern is torn writes, partial credential replacement or fail-open recovery after supply interruption. The verification package for this page therefore uses power-cut campaign; NVM consistency check; renewal-interruption test and records the tested revision/configuration so the result can be traced when the design changes.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-PWR-001 | power integrity around credential operations shall be implemented with explicit ownership, validity rules and bounded behavior for the released configuration. | Power-cut campaign. |
| ZTIP-PWR-002 | The design shall detect or contain torn writes, partial credential replacement or fail-open recovery after supply interruption before it can violate the stated trust, availability or interface boundary. | Targeted power integrity around credential operations fault injection and diagnostic-state correlation. |
| ZTIP-PWR-003 | Release of this function shall require power-cut campaign; NVM consistency check; renewal-interruption test; an unresolved result keeps the affected configuration open. | power integrity around credential operations release checklist and configuration-status audit. |

### Verification, margin and future-change rule

For power integrity around credential operations, reassess the release argument when any of these change: supply rail, brownout threshold, NVM technology, commit protocol or hold-up design. Regression for power integrity around credential operations shall target only the assumptions changed and shall preserve traceability to the prior power-cut campaign evidence rather than repeating unrelated qualification by default.

# POWER & THERMAL LIMITS FOR SECURE OPERATION

thermal and power conditions affecting trust functions is a product-owned mechanism with installation dependencies documented separately. The module is designed for low-power sensor integration, but cryptographic bursts, provisioning and radio-adjacent placement can change local heating. Security behavior must remain valid within the approved installation envelope. For thermal and power conditions affecting trust functions, that separation keeps deployment choices visible without turning them into hidden assumptions inside the product claim.

Risk analysis centers on temperature or supply margin degrading secure-element, tamper or memory behavior without detection. Instead of inventing a missing margin, the program keeps the unresolved parameter visible and closes it through thermal characterization; supply-corner test; stress/recovery verification; operational containment and product-release approval remain separate decisions.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-THM-001 | The product shall preserve the intended function of thermal and power conditions affecting trust functions across the operational states defined for the installation. | Thermal characterization. |
| ZTIP-THM-002 | A fault involving temperature or supply margin degrading secure-element, tamper or memory behavior without detection shall produce a diagnosable state and shall not silently expand authority beyond the approved boundary. | Negative-path test for thermal and power conditions affecting trust functions with recovery-state observation. |
| ZTIP-THM-003 | Qualification shall close thermal characterization; supply-corner test; stress/recovery verification with results traceable to the tested hardware, software and configuration. | Variant evidence review for thermal and power conditions affecting trust functions and production-approval gate. |

### Verification, margin and future-change rule

For thermal and power conditions affecting trust functions, reassess the release argument when any of these change: enclosure thermal path, duty cycle, regulator, host placement, crypto workload or component family. Regression for thermal and power conditions affecting trust functions shall target only the assumptions changed and shall preserve traceability to the prior thermal characterization evidence rather than repeating unrelated qualification by default.

# EPOXY ENCAPSULATION & MICRO-PROBING RESISTANCE

The released architecture assigns epoxy encapsulation as a physical attack barrier its own assurance boundary. Encapsulated epoxy resin is part of the physical resistance strategy against micro-probing. Potting must not introduce voids, mechanical stress or contamination that undermines electrical reliability or tamper sensitivity. Interfaces crossing the epoxy encapsulation as a physical attack barrier boundary carry status or validity information so a convenience service cannot silently acquire trusted authority.

Failure analysis addresses poor encapsulation creating probe paths, damaging components or masking tamper events. Diagnostic outputs must distinguish bad input, internal malfunction and incomplete engineering evidence, while process cross-section; destructive inspection; environmental aging test provides the objective basis for closing the mechanism.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-ENC-001 | epoxy encapsulation as a physical attack barrier shall have a controlled interface contract covering initialization, normal service, fault handling and authorized maintenance. | Process cross-section. |
| ZTIP-ENC-002 | The implementation shall prevent poor encapsulation creating probe paths, damaging components or masking tamper events from being accepted as valid trusted behavior or bypassing local protection logic. | Boundary-condition campaign for epoxy encapsulation as a physical attack barrier with event-log review. |
| ZTIP-ENC-003 | Production equivalence for this function depends on process cross-section; destructive inspection; environmental aging test; a changed dependency reopens the affected regression. | epoxy encapsulation as a physical attack barrier traceability audit with regression-closure review. |

### Verification, margin and future-change rule

For epoxy encapsulation as a physical attack barrier, reassess the release argument when any of these change: resin formulation, cure cycle, fill method, PCB finish, rework policy or supplier. Regression for epoxy encapsulation as a physical attack barrier shall target only the assumptions changed and shall preserve traceability to the prior process cross-section evidence rather than repeating unrelated qualification by default.

# MECHANICAL STACK, TAMPER EVIDENCE & INTERFACE ACCESS

Across startup, normal service, degraded operation and authorized recovery, mechanical packaging around protected interfaces must preserve the behavior described here. Physical packaging controls access to debug, test and host-interface nodes while preserving the electrical and thermal interfaces required by the sensor host. Serviceability cannot create an undocumented bypass. State transitions for mechanical packaging around protected interfaces are verified from observable conditions rather than inferred from nominal success alone.

A credible assurance case must show that accessible test pads, seams or rework paths bypassing the tamper boundary. Verification uses mechanical review; physical penetration test; service-tool audit across nominal, boundary and injected-fault conditions, with dependency versions retained so later regression can be scoped technically.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-MEC-001 | The architecture shall provide observability for mechanical packaging around protected interfaces sufficient to distinguish valid operation from degraded or compromised conditions. | Mechanical review. |
| ZTIP-MEC-002 | When accessible test pads, seams or rework paths bypassing the tamper boundary occurs, containment shall follow the defined policy and retain the evidence needed for diagnosis. | Injected-failure test for mechanical packaging around protected interfaces with containment and restart evidence. |
| ZTIP-MEC-003 | Acceptance shall be based on mechanical review; physical penetration test; service-tool audit, including configuration traceability where it affects the conclusion. | mechanical packaging around protected interfaces configuration baseline and qualification-status review. |

### Verification, margin and future-change rule

For mechanical packaging around protected interfaces, reassess the release argument when any of these change: enclosure, PCB stack, connector, test pads, sealing method, repair process or host mounting. Regression for mechanical packaging around protected interfaces shall target only the assumptions changed and shall preserve traceability to the prior mechanical review evidence rather than repeating unrelated qualification by default.

# SIDE-CHANNEL & FAULT-INJECTION RESILIENCE EVIDENCE

Engineering ownership of resilience evidence for physical side-channel and fault-injection attempts includes its dependencies and failure evidence. The PRD does not claim immunity to every attack technique. It requires the selected secure element and packaging to have a documented resistance argument appropriate to the deployment threat model. The release record therefore ties resilience evidence for physical side-channel and fault-injection attempts to the exact implementation and configured external services used in verification.

The release risk is simple power, clock, voltage or EM fault techniques bypassing authentication or revealing long-lived secrets. Evidence from supplier assurance review; targeted fault injection; penetration-test record is reviewed together with interface state and recovery behavior; an engineering gap blocks the affected variant rather than being disguised as a runtime derating strategy.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-SCA-001 | resilience evidence for physical side-channel and fault-injection attempts shall be dimensioned and configured for the declared mission profile without relying on undocumented external behavior. | Supplier assurance review. |
| ZTIP-SCA-002 | The consequence of simple power, clock, voltage or EM fault techniques bypassing authentication or revealing long-lived secrets shall be bounded so that recovery, fail-closed behavior or service action remains deterministic. | Misuse-case test for resilience evidence for physical side-channel and fault-injection attempts plus diagnostic and recovery verification. |
| ZTIP-SCA-003 | Engineering release shall close supplier assurance review; targeted fault injection; penetration-test record; supplier, layout, firmware or installation changes that alter the argument require focused retest. | Production-equivalence decision record for resilience evidence for physical side-channel and fault-injection attempts. |

### Verification, margin and future-change rule

For resilience evidence for physical side-channel and fault-injection attempts, reassess the release argument when any of these change: secure-element grade, board layout, decoupling, shielding, attack model or assurance target. Regression for resilience evidence for physical side-channel and fault-injection attempts shall target only the assumptions changed and shall preserve traceability to the prior supplier assurance review evidence rather than repeating unrelated qualification by default.

## CLEAN-ROOM ROOT-OF-TRUST PROVISIONING

The product treats secure clean-room provisioning of root-of-trust certificates as a controlled capability rather than a generic platform feature. Manufacturing provisioning is a security ceremony, not just a programming step. Access to issuing credentials, device identities and provisioning stations is controlled and auditable. Any dependency of secure clean-room provisioning of root-of-trust certificates is named in the interface or configuration baseline so its loss can be distinguished from an internal defect.

The design review asks whether unauthorized certificate issuance, secret leakage or loss of device-to-record traceability. That question is answered with ceremony audit; access-control review; sample genealogy reconciliation, supplemented by negative-path observation where necessary to prove that the mechanism fails in the intended direction.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-CLN-001 | The released implementation of secure clean-room provisioning of root-of-trust certificates shall expose the status required by diagnostics and lifecycle management without disclosing protected secrets or unsafe controls. | Ceremony audit. |
| ZTIP-CLN-002 | The product shall treat unauthorized certificate issuance, secret leakage or loss of device-to-record traceability as an invalid or degraded condition rather than accepting it as nominal input. | Fault stimulation of secure clean-room provisioning of root-of-trust certificates with interface-state and audit-record review. |
| ZTIP-CLN-003 | Objective evidence for this requirement shall include ceremony audit; access-control review; sample genealogy reconciliation, using pass/fail criteria owned by the product verification plan. | DVP closure for secure clean-room provisioning of root-of-trust certificates and controlled release-board review. |

### Verification, margin and future-change rule

For secure clean-room provisioning of root-of-trust certificates, reassess the release argument when any of these change: provisioning site, HSM, operator role, certificate authority, station software or secure transport. Regression for secure clean-room provisioning of root-of-trust certificates shall target only the assumptions changed and shall preserve traceability to the prior ceremony audit evidence rather than repeating unrelated qualification by default.

# DEVICE GENEALOGY, SERIALIZATION & CREDENTIAL TRACEABILITY

Each shipped unit requires a trace from manufacturing serial identity to secure-element identity, certificate chain, firmware release and provisioning event. Records must support revocation and forensic investigation. The engineering objective for genealogy linking hardware, firmware and credentials is explicit ownership: integration teams must be able to identify the trusted inputs, permitted outputs and conditions that invalidate the result.

The dominant concern is mismatched device/certificate records or inability to determine which credential belongs to a returned unit. The verification package for this page therefore uses database reconciliation; sample reverse trace; duplicate scan and records the tested revision/configuration so the result can be traced when the design changes.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-GEN-001 | genealogy linking hardware, firmware and credentials shall be implemented with explicit ownership, validity rules and bounded behavior for the released configuration. | Database reconciliation. |
| ZTIP-GEN-002 | The design shall detect or contain mismatched device/certificate records or inability to determine which credential belongs to a returned unit before it can violate the stated trust, availability or interface boundary. | Abnormal-condition test for genealogy linking hardware, firmware and credentials and degraded-state trace review. |
| ZTIP-GEN-003 | Release of this function shall require database reconciliation; sample reverse trace; duplicate scan; an unresolved result keeps the affected configuration open. | genealogy linking hardware, firmware and credentials release checklist and configuration-status audit. |

### Verification, margin and future-change rule

For genealogy linking hardware, firmware and credentials, reassess the release argument when any of these change: serialization scheme, MES interface, certificate database, rework process or RMA flow. Regression for genealogy linking hardware, firmware and credentials shall target only the assumptions changed and shall preserve traceability to the prior database reconciliation evidence rather than repeating unrelated qualification by default.

# END-OF-LINE SECURITY & TAMPER FUNCTIONAL TEST

EOL verification of identity, tamper and onboarding functions is a product-owned mechanism with installation dependencies documented separately. EOL test confirms that security state is correctly provisioned without exposing reusable secrets to the tester. Tamper and fail-closed behavior are sampled or exercised according to the approved manufacturing control plan. For eol verification of identity, tamper and onboarding functions, that separation keeps deployment choices visible without turning them into hidden assumptions inside the product claim.

Risk analysis centers on a unit shipping with missing identity, disabled tamper path or debug access left open. Instead of inventing a missing margin, the program keeps the unresolved parameter visible and closes it through EOL functional test; secure-state readback; debug-lock audit; operational containment and product-release approval remain separate decisions.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-EOL-001 | The product shall preserve the intended function of EOL verification of identity, tamper and onboarding functions across the operational states defined for the installation. | Eol functional test. |
| ZTIP-EOL-002 | A fault involving a unit shipping with missing identity, disabled tamper path or debug access left open shall produce a diagnosable state and shall not silently expand authority beyond the approved boundary. | Stress/fault test for eol verification of identity, tamper and onboarding functions with recovery and non-bypass evidence. |
| ZTIP-EOL-003 | Qualification shall close EOL functional test; secure-state readback; debug-lock audit with results traceable to the tested hardware, software and configuration. | Variant evidence review for eol verification of identity, tamper and onboarding functions and production-approval gate. |

### Verification, margin and future-change rule

For eol verification of identity, tamper and onboarding functions, reassess the release argument when any of these change: fixture, test command set, sampling plan, debug fuse policy or station credential. Regression for eol verification of identity, tamper and onboarding functions shall target only the assumptions changed and shall preserve traceability to the prior EOL functional test evidence rather than repeating unrelated qualification by default.

# DESTRUCTIVE TAMPER TEST COVERAGE & PROCESS MONITORING

The released architecture assigns destructive tamper validation and process surveillance its own assurance boundary. Some physical-security evidence necessarily destroys the sample. The control plan therefore combines destructive qualification samples with nondestructive in-line indicators that monitor the same critical process characteristics. Interfaces crossing the destructive tamper validation and process surveillance boundary carry status or validity information so a convenience service cannot silently acquire trusted authority.

Failure analysis addresses production drift in tamper mesh or encapsulation escaping routine functional test. Diagnostic outputs must distinguish bad input, internal malfunction and incomplete engineering evidence, while destructive sample campaign; process capability; in-line monitor correlation provides the objective basis for closing the mechanism.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-DTT-001 | destructive tamper validation and process surveillance shall have a controlled interface contract covering initialization, normal service, fault handling and authorized maintenance. | Destructive sample campaign. |
| ZTIP-DTT-002 | The implementation shall prevent production drift in tamper mesh or encapsulation escaping routine functional test from being accepted as valid trusted behavior or bypassing local protection logic. | Targeted destructive tamper validation and process surveillance fault injection and diagnostic-state correlation. |
| ZTIP-DTT-003 | Production equivalence for this function depends on destructive sample campaign; process capability; in-line monitor correlation; a changed dependency reopens the affected regression. | destructive tamper validation and process surveillance traceability audit with regression-closure review. |

### Verification, margin and future-change rule

For destructive tamper validation and process surveillance, reassess the release argument when any of these change: sample rate, mesh process, potting process, supplier lot, test method or acceptance criteria. Regression for destructive tamper validation and process surveillance shall target only the assumptions changed and shall preserve traceability to the prior destructive sample campaign evidence rather than repeating unrelated qualification by default.

# SECURE OTA CERTIFICATE RENEWAL & UPDATE AUTHORITY

Across startup, normal service, degraded operation and authorized recovery, secure ota renewal and update authority must preserve the behavior described here. Long-life deployment requires controlled certificate renewal without opening a generic remote administration path. Update authority, package authenticity and rollback behavior are separate from ordinary application traffic. State transitions for secure ota renewal and update authority are verified from observable conditions rather than inferred from nominal success alone.

A credible assurance case must show that remote renewal mechanism being used to install unauthorized trust state or strand devices after interruption. Verification uses signed-update test; interrupted-renewal recovery; privilege review across nominal, boundary and injected-fault conditions, with dependency versions retained so later regression can be scoped technically.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-OTA-001 | The architecture shall provide observability for secure OTA renewal and update authority sufficient to distinguish valid operation from degraded or compromised conditions. | Signed-update test. |
| ZTIP-OTA-002 | When remote renewal mechanism being used to install unauthorized trust state or strand devices after interruption occurs, containment shall follow the defined policy and retain the evidence needed for diagnosis. | Negative-path test for secure ota renewal and update authority with recovery-state observation. |
| ZTIP-OTA-003 | Acceptance shall be based on signed-update test; interrupted-renewal recovery; privilege review, including configuration traceability where it affects the conclusion. | secure OTA renewal and update authority configuration baseline and qualification-status review. |

### Verification, margin and future-change rule

For secure ota renewal and update authority, reassess the release argument when any of these change: update signer, transport, package format, rollback policy, recovery credential or network service. Regression for secure ota renewal and update authority shall target only the assumptions changed and shall preserve traceability to the prior signed-update test evidence rather than repeating unrelated qualification by default.

# ROLLBACK PROTECTION & AUTHORIZED RECOVERY

Engineering ownership of anti-rollback and recovery authorization includes its dependencies and failure evidence. Recovery restores service after failed updates or credential problems without accepting obsolete vulnerable firmware or revoked trust material. Exceptional factory recovery is itself authenticated and audited. The release record therefore ties anti-rollback and recovery authorization to the exact implementation and configured external services used in verification.

The release risk is rollback to vulnerable state or uncontrolled factory reset re-establishing revoked credentials. Evidence from rollback-negative test; recovery-authentication test; audit trail review is reviewed together with interface state and recovery behavior; an engineering gap blocks the affected variant rather than being disguised as a runtime derating strategy.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-RBK-001 | anti-rollback and recovery authorization shall be dimensioned and configured for the declared mission profile without relying on undocumented external behavior. | Rollback-negative test. |
| ZTIP-RBK-002 | The consequence of rollback to vulnerable state or uncontrolled factory reset re-establishing revoked credentials shall be bounded so that recovery, fail-closed behavior or service action remains deterministic. | Boundary-condition campaign for anti-rollback and recovery authorization with event-log review. |
| ZTIP-RBK-003 | Engineering release shall close rollback-negative test; recovery-authentication test; audit trail review; supplier, layout, firmware or installation changes that alter the argument require focused retest. | Production-equivalence decision record for anti-rollback and recovery authorization. |

### Verification, margin and future-change rule

For anti-rollback and recovery authorization, reassess the release argument when any of these change: version counter, recovery image, factory token, service role or secure element policy. Regression for anti-rollback and recovery authorization shall target only the assumptions changed and shall preserve traceability to the prior rollback-negative test evidence rather than repeating unrelated qualification by default.

# SECURITY AUDIT EVENTS, COUNTERS & FORENSIC SUPPORT

The product treats security audit events and protected counters as a controlled capability rather than a generic platform feature. The module records trust-relevant events such as tamper detection, failed onboarding, credential rotation, renewal failure and recovery without logging private keys or unnecessary sensitive material. Any dependency of security audit events and protected counters is named in the interface or configuration baseline so its loss can be distinguished from an internal defect.

The design review asks whether loss or manipulation of security evidence preventing diagnosis of repeated attacks or lifecycle problems. That question is answered with event-injection test; log-integrity review; privacy/content audit, supplemented by negative-path observation where necessary to prove that the mechanism fails in the intended direction.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-AUD-001 | The released implementation of security audit events and protected counters shall expose the status required by diagnostics and lifecycle management without disclosing protected secrets or unsafe controls. | Event-injection test. |
| ZTIP-AUD-002 | The product shall treat loss or manipulation of security evidence preventing diagnosis of repeated attacks or lifecycle problems as an invalid or degraded condition rather than accepting it as nominal input. | Injected-failure test for security audit events and protected counters with containment and restart evidence. |
| ZTIP-AUD-003 | Objective evidence for this requirement shall include event-injection test; log-integrity review; privacy/content audit, using pass/fail criteria owned by the product verification plan. | DVP closure for security audit events and protected counters and controlled release-board review. |

### Verification, margin and future-change rule

For security audit events and protected counters, reassess the release argument when any of these change: event schema, storage capacity, export interface, retention rule or time source. Regression for security audit events and protected counters shall target only the assumptions changed and shall preserve traceability to the prior event-injection test evidence rather than repeating unrelated qualification by default.

# NERC CIP DEPLOYMENT MAPPING & CONTROL OWNERSHIP

The target market includes operators requiring NERC CIP compliance. Product evidence therefore supports asset identity, access control, change traceability and secure maintenance, while final compliance allocation remains with the deployment owner. The engineering objective for deployment mapping for nerc cip-oriented critical infrastructure is explicit ownership: integration teams must be able to identify the trusted inputs, permitted outputs and conditions that invalidate the result.

The dominant concern is product marketing implying unsupported standalone compliance or missing evidence needed by the operator control framework. The verification package for this page therefore uses requirements-to-control mapping; deployment review; audit-evidence sample and records the tested revision/configuration so the result can be traced when the design changes.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-CIP-001 | deployment mapping for NERC CIP-oriented critical infrastructure shall be implemented with explicit ownership, validity rules and bounded behavior for the released configuration. | Requirements-to-control mapping. |
| ZTIP-CIP-002 | The design shall detect or contain product marketing implying unsupported standalone compliance or missing evidence needed by the operator control framework before it can violate the stated trust, availability or interface boundary. | Misuse-case test for deployment mapping for nerc cip-oriented critical infrastructure plus diagnostic and recovery verification. |
| ZTIP-CIP-003 | Release of this function shall require requirements-to-control mapping; deployment review; audit-evidence sample; an unresolved result keeps the affected configuration open. | deployment mapping for NERC CIP-oriented critical infrastructure release checklist and configuration-status audit. |

### Verification, margin and future-change rule

For deployment mapping for nerc cip-oriented critical infrastructure, reassess the release argument when any of these change: operator control interpretation, site architecture, access policy, maintenance process or regulatory revision. Regression for deployment mapping for nerc cip-oriented critical infrastructure shall target only the assumptions changed and shall preserve traceability to the prior requirements-to-control mapping evidence rather than repeating unrelated qualification by default.

# EMC, ESD & INDUSTRIAL ENVIRONMENTAL ROBUSTNESS

electromagnetic and environmental robustness of security functions is a product-owned mechanism with installation dependencies documented separately. Industrial installations can expose low-power identity modules to ESD, EFT, conducted noise and host transients. Disturbance must not create a permissive trust state or silently damage tamper observability. For electromagnetic and environmental robustness of security functions, that separation keeps deployment choices visible without turning them into hidden assumptions inside the product claim.

Risk analysis centers on EM disturbance causing resets, false trust acceptance or latent security-state corruption. Instead of inventing a missing margin, the program keeps the unresolved parameter visible and closes it through EMC immunity test; post-stress security regression; reset-state review; operational containment and product-release approval remain separate decisions.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-EMC-001 | The product shall preserve the intended function of electromagnetic and environmental robustness of security functions across the operational states defined for the installation. | Emc immunity test. |
| ZTIP-EMC-002 | A fault involving EM disturbance causing resets, false trust acceptance or latent security-state corruption shall produce a diagnosable state and shall not silently expand authority beyond the approved boundary. | Fault stimulation of electromagnetic and environmental robustness of security functions with interface-state and audit-record review. |
| ZTIP-EMC-003 | Qualification shall close EMC immunity test; post-stress security regression; reset-state review with results traceable to the tested hardware, software and configuration. | Variant evidence review for electromagnetic and environmental robustness of security functions and production-approval gate. |

### Verification, margin and future-change rule

For electromagnetic and environmental robustness of security functions, reassess the release argument when any of these change: host cable, enclosure, grounding, filter network, secure element, PCB layout or environment class. Regression for electromagnetic and environmental robustness of security functions shall target only the assumptions changed and shall preserve traceability to the prior EMC immunity test evidence rather than repeating unrelated qualification by default.

# PRODUCT DVP, NEGATIVE TESTING & RELEASE EVIDENCE

The released architecture assigns the integrated verification plan for identity, tamper, power and lifecycle behavior its own assurance boundary. Release evidence combines cryptographic interoperability, tamper response, onboarding, low-power behavior, update/recovery, manufacturing and environmental tests. Missing evidence keeps the relevant variant open rather than inventing a runtime workaround. Interfaces crossing the the integrated verification plan for identity, tamper, power and lifecycle behavior boundary carry status or validity information so a convenience service cannot silently acquire trusted authority.

Failure analysis addresses fragmented subsystem evidence leaving an untested end-to-end trust path. Diagnostic outputs must distinguish bad input, internal malfunction and incomplete engineering evidence, while DVP coverage audit; cross-domain fault campaign; release-readiness review provides the objective basis for closing the mechanism.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-DVP-001 | the integrated verification plan for identity, tamper, power and lifecycle behavior shall have a controlled interface contract covering initialization, normal service, fault handling and authorized maintenance. | Dvp coverage audit. |
| ZTIP-DVP-002 | The implementation shall prevent fragmented subsystem evidence leaving an untested end-to-end trust path from being accepted as valid trusted behavior or bypassing local protection logic. | Abnormal-condition test for the integrated verification plan for identity, tamper, power and lifecycle behavior and degraded-state trace review. |
| ZTIP-DVP-003 | Production equivalence for this function depends on DVP coverage audit; cross-domain fault campaign; release-readiness review; a changed dependency reopens the affected regression. | the integrated verification plan for identity, tamper, power and lifecycle behavior traceability audit with regression-closure review. |

### Verification, margin and future-change rule

For the integrated verification plan for identity, tamper, power and lifecycle behavior, reassess the release argument when any of these change: architecture, threat model, software, hardware, provisioning process, supplier or deployment profile. Regression for the integrated verification plan for identity, tamper, power and lifecycle behavior shall target only the assumptions changed and shall preserve traceability to the prior DVP coverage audit evidence rather than repeating unrelated qualification by default.

# 15-YEAR CERTIFICATE, OBSOLESCENCE & SERVICE LIFECYCLE

Across startup, normal service, degraded operation and authorized recovery, the 15-year credential and product lifecycle must preserve the behavior described here. The stated lifecycle includes automated certificate expiry monitoring and secure OTA renewal over 15 years. Obsolescence, cryptographic migration and field replacement are managed without breaking device genealogy or revocation history. State transitions for the 15-year credential and product lifecycle are verified from observable conditions rather than inferred from nominal success alone.

A credible assurance case must show that credential, secure-element or tool obsolescence making deployed devices unmaintainable or unverifiable. Verification uses lifecycle plan; renewal simulation; obsolescence review across nominal, boundary and injected-fault conditions, with dependency versions retained so later regression can be scoped technically.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-LIF-001 | The architecture shall provide observability for the 15-year credential and product lifecycle sufficient to distinguish valid operation from degraded or compromised conditions. | Lifecycle plan. |
| ZTIP-LIF-002 | When credential, secure-element or tool obsolescence making deployed devices unmaintainable or unverifiable occurs, containment shall follow the defined policy and retain the evidence needed for diagnosis. | Stress/fault test for the 15-year credential and product lifecycle with recovery and non-bypass evidence. |
| ZTIP-LIF-003 | Acceptance shall be based on lifecycle plan; renewal simulation; obsolescence review, including configuration traceability where it affects the conclusion. | the 15-year credential and product lifecycle configuration baseline and qualification-status review. |

### Verification, margin and future-change rule

For the 15-year credential and product lifecycle, reassess the release argument when any of these change: certificate authority, cryptographic profile, secure element, provisioning tool, service backend or replacement process. Regression for the 15-year credential and product lifecycle shall target only the assumptions changed and shall preserve traceability to the prior lifecycle plan evidence rather than repeating unrelated qualification by default.

# SUPPLIER, SECOND-SOURCE & PRODUCTION-EQUIVALENCE CLOSURE

Engineering ownership of supplier and second-source equivalence for security-critical components includes its dependencies and failure evidence. A changed secure element, tamper material, encapsulant or manufacturing service is not production-equivalent by declaration. The security, electrical and process evidence affected by the change is identified and repeated. The release record therefore ties supplier and second-source equivalence for security-critical components to the exact implementation and configured external services used in verification.

The release risk is second-source introduction weakening trust, physical resistance or provisioning assurance without regression evidence. Evidence from similarity analysis; delta-DVP; configuration release board review is reviewed together with interface state and recovery behavior; an engineering gap blocks the affected variant rather than being disguised as a runtime derating strategy.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-SRC-001 | supplier and second-source equivalence for security-critical components shall be dimensioned and configured for the declared mission profile without relying on undocumented external behavior. | Similarity analysis. |
| ZTIP-SRC-002 | The consequence of second-source introduction weakening trust, physical resistance or provisioning assurance without regression evidence shall be bounded so that recovery, fail-closed behavior or service action remains deterministic. | Targeted supplier and second-source equivalence for security-critical components fault injection and diagnostic-state correlation. |
| ZTIP-SRC-003 | Engineering release shall close similarity analysis; delta-DVP; configuration release board review; supplier, layout, firmware or installation changes that alter the argument require focused retest. | Production-equivalence decision record for supplier and second-source equivalence for security-critical components. |

### Verification, margin and future-change rule

For supplier and second-source equivalence for security-critical components, reassess the release argument when any of these change: secure element, PCB supplier, encapsulant, certificate service, provisioning site or test fixture. Regression for supplier and second-source equivalence for security-critical components shall target only the assumptions changed and shall preserve traceability to the prior similarity analysis evidence rather than repeating unrelated qualification by default.

# FINAL RELEASE CLOSURE & FUTURE-CHANGE GOVERNANCE

The product treats final release closure and controlled future change as a controlled capability rather than a generic platform feature. Final release requires traceable closure of identity architecture, fail-closed behavior, manufacturing provisioning, lifecycle renewal and deployment assumptions. Open TBCs remain visible with owners and due gates. Any dependency of final release closure and controlled future change is named in the interface or configuration baseline so its loss can be distinguished from an internal defect.

The design review asks whether future changes silently invalidating the trust argument or producing mixed incompatible field populations. That question is answered with release checklist; open-item audit; change-impact and regression review, supplemented by negative-path observation where necessary to prove that the mechanism fails in the intended direction.

### Atomic product requirements

| Requirement ID | Single-intent requirement | Verification / release evidence |
|---|---|---|
| ZTIP-CLS-001 | The released implementation of final release closure and controlled future change shall expose the status required by diagnostics and lifecycle management without disclosing protected secrets or unsafe controls. | Release checklist. |
| ZTIP-CLS-002 | The product shall treat future changes silently invalidating the trust argument or producing mixed incompatible field populations as an invalid or degraded condition rather than accepting it as nominal input. | Negative-path test for final release closure and controlled future change with recovery-state observation. |
| ZTIP-CLS-003 | Objective evidence for this requirement shall include release checklist; open-item audit; change-impact and regression review, using pass/fail criteria owned by the product verification plan. | DVP closure for final release closure and controlled future change and controlled release-board review. |

### Verification, margin and future-change rule

For final release closure and controlled future change, reassess the release argument when any of these change: any change to trust roots, host protocol, manufacturing, update path, physical barrier, lifecycle service or deployment model. Regression for final release closure and controlled future change shall target only the assumptions changed and shall preserve traceability to the prior release checklist evidence rather than repeating unrelated qualification by default.